

CINNAMON: A Module for AUTOSAR Secure Onboard Communication

Giampaolo Bella, Pietro Biondi
Dipartimento di Matematica e Informatica
Università degli Studi di Catania
Catania, Italy
giamp@dmf.unict.it,
pietro.biondi@phd.unict.it

Gianpiero Costantino, Ilaria Matteucci
Istituto di Informatica e Telematica
Consiglio Nazionale delle Ricerche
Pisa, Italy
gianpiero.costantino@iit.cnr.it,
ilaria.matteucci@iit.cnr.it

Abstract—This paper introduces CINNAMON, a software module that extends and seamlessly integrates with the AUTOSAR “Secure Onboard Communication” (SecOC) module [3], [5] to also account for confidentiality of data in transit. It stands for Confidential, INtegral aNd Authentic on board coMunicatiON (CINNAMON). It takes a resource-efficient and practical approach to ensure, at the same time, confidentiality, integrity and authenticity of frames. The main new requirement that CINNAMON puts forward is the use of encryption and thus, as a result, CINNAMON exceeds SecOC against *information gathering* attacks.

This paper sets forth the essential requirements and specification of the new module by detailing where and how to position it within AUTOSAR and by emphasizing the relevant upgrades with respect to SecOC. The presentation continues with the definition of a Security Profile and a summary of a prototype implementation of ours [8], [9]. While CINNAMON is easily extensible, for example through the definition of additional profiles, the current performances obtained on inexpensive boards support the claim that the approach is feasible.

Index Terms—Automotive, Vehicle, CAN Bus, Cybersecurity, Data Protection.

I. INTRODUCTION

Encryption is a *de facto* standard to protect data while in transit. Many examples come in support of this claim, such as client-server communications over HTTPS and popular chat services pervasively exposed via mobile apps. Encryption is also one of the measures that (art. 32 of) the General Data Protection Regulation advocates to protect personal data in any application scenario that treats such data [28]. The European Data Protection Board underlines “*the context of connected vehicles and mobility related applications*” as one such scenario and explicitly calls for encryption [17, §2.7]. It can be observed, however, that in-vehicle communications are not encrypted at present, and in fact the AUTOSAR SecOC module [3] only prescribes integrity and authenticity, as detailed below.

We contend that encryption ought to be added also to in-vehicle communications hence define CINNAMON, a module that requires encryption over the Controller Area Network (CAN). The pervasiveness of the applications of encryption outlined above somehow contributes to the motivation

for our work. More importantly, a proof-of-concept of ours already demonstrated that the computational overhead can be negligible on currently inexpensive hardware [8], [9], so feasibility increases our motivation significantly. Nonetheless, our main impulse is to counter *information gathering* attacks, which may have dramatic consequences also at CAN bus level, such as the reverse engineering of proprietary mapping, normally stored in a *Database CAN* (DBC) file [15], [29]. A DBC stores the mapping between CAN frame payloads and functionalities of a vehicle, as decided by the Original Equipment Manufacturer (OEM). Therefore, a DBC is a clear aim for an attacker because it enables the Electronic Control Units (ECUs) of a specific vehicle to correctly interpret the payload values and translate them into signals that carry out the expected functionalities. Moreover, information gathering attacks may also be oriented at driver privacy infringement through profiling [11], [24].

The number of ECUs in a modern vehicle ranges from a few tens to over a hundred. To communicate with one another, ECUs may adopt several buses, such as the Controller Area Network [12], FlexRay [14], Ethernet [32]. In particular, the CAN bus is still the most widespread at present. It leverages a binary language, standardised as ISO 11898-1:2015, to derive a simple protocol based on two bus lines [21]. However, CAN is not secure-by-design because authentication, integrity and confidentiality are not considered in the design and implementation of the protocol. This represents one of the main vulnerabilities of modern vehicles: getting (local or remote) access to CAN bus allows an attacker to inject unauthorised frames on the bus. These frames may compromise the functionalities of the target vehicle, eventually making them unsafe, as detailed below through the description of the threat model. There comes a non negligible inherent risk of, for example, malicious attacks against a vehicle, including remote control, as we shall detail in the next Section through real-world episodes.

AUTOSAR collects most of the strategies and guidelines that regulate the automotive world. AUTOSAR depicts a Classic Platform, which is a Software Platform defined for deeply embedded systems and Application Software with high demands regarding predictability, safety and responsiveness. AUTOSAR covers functional safety and security aspects

of onboard communications. As for the latter, AUTOSAR proposes the *Secure On Board Communication* Basic Software (BSW) module, named SecOC, listing its requirements [3] and providing its specification [5]. SecOC insists on the integrity of onboard communications and the authenticity of ECUs that act as senders. By contrast, it does not consider confidentiality.

This paper introduces the CINNAMON module, whose requirements leverage and extend those already provided by SecOC [3]. Therefore, CINNAMON is an AUTOSAR compliant Basic Software (BSW) module and insists not only on authenticity and integrity (as SecOC does) but also on confidentiality of CAN bus communications.

CINNAMON aims at countering the information gathering (reverse engineering) activities of attackers by prescribing the symmetric-key encryption of frames that are in transit on the CAN bus. In consequence, the attacker will not be able to read frame data fields unless she compromises at least one ECU to get the encryption key. Thus, CINNAMON exceeds SecOC by design in the mitigation of information gathering attacks.

This paper is structured as follows. The next Section describes the assumed threat model. Section III recalls the main features of SecOC. Section IV describes CINNAMON through its requirements, its specification and its security profiles. Section V provides an informal security assessment of the new module. Section VII compares our contribution with the relevant literature, and Section VIII draws hints for future work and conclusions.

II. THREAT MODEL

Recent history about automotive security shows several examples of attacks to real vehicles. In 2010, researchers showed how to control a car remotely, that is, make the car engine exploitable, turn off the brakes so that the vehicle would not stop, and make instruments give false readings [6]. In 2015, hijacking was perpetrated on a Jeep Cherokee [29] and also on a General Motors vehicle [22]. Hackers remotely took control of the engine and stole data from the infotainment system. They exploited the Internet connection of the infotainment system as well as a malicious version of the infotainment software installed on the car. In 2016, researchers hacked a TESLA Model S [13] by using bugs on the TESLA's bounty program through which vehicles received firmware updates. All these attacks leverage the lack of confidentiality for data in transit on the intra-vehicle CAN bus network, which are, consequently, exposed to several threats, hence the motivation for our work rises.

This paper assumes a threat model with an active attacker who may exploit some vulnerabilities of a car to gain some digital access to the car, either locally or remotely. More precisely, our attacker:

- may acquire pieces of information about the running protocols and other mechanisms in place in the network she observes,
- may build and inject frames at will to manipulate the information processed by the target ECUs,
- may not obtain privileged access to any ECUs.

Therefore, our threat model assumes the attacker to only have partial control of ECUs, hence she only has partial access to its functionalities. This would be the case, for example, when a Hardware Security Module (HSM) or similar solutions are adopted to protect cryptographic keys and run security-critical operations such as encryption.

In practice, the attacker may try to modify the behaviour of a target vehicle by sending customized CAN frames to trigger a specific functionality on a receiving ECU. The attacker in general *aims* to mount the following attacks:

- *Replay*: re-use of valid CAN frames with malicious or fraudulent aims.
- *Tampering*: manipulation of CAN frames to spoil their contents so that a receiving ECU cannot perform the operation that was originally meant.
- *Forging*: generation of a valid CAN frame, which is then able to generate a valid signal and activate a specific ECU functionality.
- *Fuzzing*: injection of CAN frames, which were previously forged, with the aim of studying the behaviour of a target ECU against unexpected inputs.
- *Masquerading*: misinterpretation of attacker's identity by using a CAN ID of some other genuine ECU, thereby masquerading as that ECU.
- *Information Gathering*: identification of critical contents from CAN frames, such as the frame ID or payload and its associated ECU functionality, with the aim of using it against a target ECU to perform a post-attack.

To mitigate such an attacker, we argue that a secure CAN protocol should achieve the following security properties:

- **Confidentiality**. The content of a frame is not disclosed to unauthorised entities.
- **Authentication**. The identity of the sender of a frame can be verified.
- **Integrity**. The content of a frame is not altered during transmission.
- **Freshness**. It can be verified whether a frame was already received.

III. A PRIMER ON THE SECURE ON BOARD COMMUNICATION

In the AUTOSAR Classic Platform, security of onboard communication is managed by a *Basic Software Module*, SecOC, which is part of the *Communication Services* (Fig. 1). A Basic Software Module in AUTOSAR is a collection of documents to define a certain basic software functionality that may be deployed on an ECU.

AUTOSAR provides the list of all SecOC requirements [3]. Such requirements regulate functional as well as non functional aspects. More precisely, non functional requirements regulate the responsiveness of the module with respect to message communication.

The SecOC module must be deployed over all communicating ECUs. In return, SecOC enables each ECU to verify the received messages in terms of authenticity and integrity

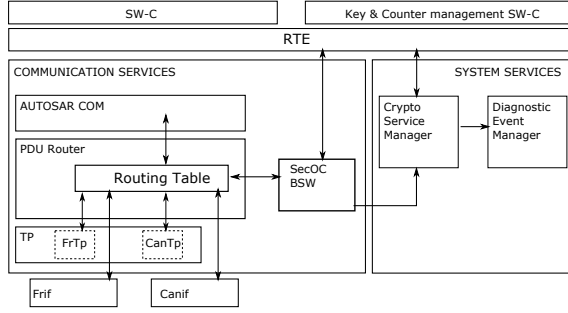


Fig. 1: Integrating SecOC BSW module in AUTOSAR [5]

through a Message Authentication Code (MAC) and in terms of freshness through the use of special counters, as we shall see below. Independently from the specific protocol, exchanged messages are in general addressed as Protocol Data Units (PDUs), thus the SecOC Secure PDU can be depicted as in Fig. 2.

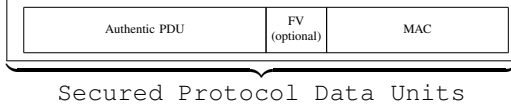


Fig. 2: Secured Protocol Data Units contents

As it is designed, the SecOC module is able to overcome all the attacks listed in §II except Information Gathering attacks, as the sequel of this paper demonstrates.

IV. THE CINNAMON MODULE

The CINNAMON BSW module leverages the SecOC design for what concerns authentication and integrity and adds confidentiality by introducing and regulating the use of cryptography. In this first version, CINNAMON intends to secure only the CAN bus, so PDUs can be concretely seen as CAN frames.

A. Requirements

This Section reviews the SecOC Requirements [3] and how they are inherited and upgraded in CINNAMON to fulfill the objectives of confidentiality, integrity and authenticity. Requirements that are inherited unaltered are normally not presented, except when they raise relevant discussion. Each requirement comes with a Status field representing to what extent the current prototype implementation covers it.

a) Functional: CINNAMON_00003 (Table I) configures different security properties. The security expert is in charge of defining the level of protection of onboard communication frames and the parameters needed to configure the functionalities of the module.

CINNAMON satisfies this requirement by configuring confidentiality, authentication and integrity properties. Therefore, in addition to the SecOC module, it also manages the parameters needed for encryption and decryption to work.

TABLE I: CINNAMON_00003

Functional Requirement	Configuration of different security properties/requirements
Type:	Valid
Description:	Different security properties, including confidentiality, shall be configurable.
Rationale:	The assessment may vary in several parameters and its security needs. Thus the level of protection shall be configurable to adapt to these needs by means of a set of adequate parameters.
Use Case:	Security experts define the different security properties, including confidentiality. For every frame with security protection needs, the appropriate properties may be selected.
Corresponding SecOC Requirement	SRS_SecOC_00003
Status	Accomplished

b) Initialisation: CINNAMON_00005 (Table II) regulates also encryption and decryption functionalities.

With respect to SRS_SecOC_00005 requirement, the security configuration details in CINNAMON are not only restricted to Key-IDs for authentication and Freshness Values but also expand on the Key-IDs for encryption and decryption.

TABLE II: CINNAMON_00005

Initialisation	Initialisation of security information
Type:	Valid
Description:	CINNAMON security configuration shall get initialised at module start-up.
Rationale:	CINNAMON needs security configuration information e.g., Key-IDs for authentication, Freshness Values, and encryption/decryption to perform its operations. Therefore, this information shall get recovered and configured before it starts its processing operation.
Use Case:	CINNAMON loads the ID of frames, the authorized authentication retry counter, the used encryption mechanism and the properties that are used for the processing of its incoming communications from upper and lower layers.
Corresponding SecOC Requirement	SRS_SecOC_00005
Status	Accomplished

c) Normal Operations: CINNAMON_00012 (Table III) requires the use of the module for different kinds of bus systems. It is a noteworthy requirement because, at the current stage, CINNAMON is only designed for the CAN bus and this is reflected by the 'Partially accomplished' Status. We anticipate that further versions of our module could be extended for confidentiality on other protocol buses in the future.

TABLE III: CINNAMON_00012

Normal Operations	Support of Automotive BUS Systems
Type:	Valid
Description:	CINNAMON shall be applicable for the different kind of bus systems that are supported by AUTOSAR and that are typical for automotive environments.
Rationale:	All bus protocols supported by AUTOSAR shall benefit from the CINNAMON design.
Use Case:	Low bandwidth buses like CAN shall be supported as well as technologies for large data link, like Ethernet.
Corresponding SecOC Requirement	SRS_SecOC_00012
Status	Partially accomplished

CINNAMON_00030 (Table IV) requires the module to be able to extract the payload from secured frames, without authentication. In the current specification of CINNAMON this is true provided that frame decryption is performed first. On the contrarily, SecOC is capable to directly extract the data payload.

TABLE IV: CINNAMON_00030

Normal Operations	Support of capability to extract Authentic PDU without Authentication
Type:	Valid
Description:	CINNAMON shall be capable to extract the payload from Secured frames, without Authentication.
Rationale:	CINNAMON can be used as an extractor of payload from Secured frames, to enable low latency GW behaviour when a part of downstream communication clusters does not require authentication of frames.
Use Case:	Gateway.
Corresponding SecOC Requirement	SRS_SecOC_00030
Status	Partially accomplished

d) *Support for end-to-end and point-to-point protection:*

A point-to-point secure communication guarantees security between pairs of communicating ECUs. In case of a multi-hop communication, i.e., a frame circulates among several ECUs to reach a receiver ECU, each ECU authenticates the frame. An end-to-end communication guarantees security only between the sender ECU and the receiver ECU regardless of the intermediate ECUs. Frames exchanged in both communication types have to be protected.

TABLE V: CINNAMON_00013

Support for end-to-end and point-to-point protection	Support for end-to-end and point-to-point protection
Type:	Valid
Description:	Support for end-to-end and point-to-point protection.
Rationale:	While some signals are simply forwarded and no further requirements are given for the channel or relaying entities in between, other may pass through relaying entities that can do changes on the packet content and thus need to be trusted by the receiving entity.
Use Case:	An ECU communicates data that is transmitted over several logical networks with different security properties. A re-authentication gateway bridges the data from a logical network to the other and processes verification and re-authentication.
Corresponding SecOC Requirement	SRS_SecOC_00013
Status	Partially accomplished

CINNAMON aims at security on point-to-point communications. This means that, if a CAN frame passes from multiple hops, all secure mechanisms have to be performed by each hop in the communication chain. However, CINNAMON could be extended to obtain also end-to-end communication protection, by configuring the CINNAMON module so that an ECU does not act as receiver but forwards the frame.

e) *Non-Functional Requirements:* CINNAMON_00025

(Table VI) refers to computation performances. Thus, it regulates the time needed to perform all security operations, notably considering also encryption and decryption.

TABLE VI: CINNAMON_00025

Non-Functional Requirements (Timing)	Authentication and verification processing time
Type:	Valid
Description:	Authentication, verification, encryption and decryption processing shall be performed in a timely fashion so that the real time critical signals do not get affected.
Rationale:	Transmission and reception of the time critical frame between the running applications of two or more peers shall not get penalised by the additional processing of their underlying communication software layers such that the signals are finally rejected. It is necessary that when time critical frames are transmitted and received through a Secured frames, the additional processing required by CINNAMON remains under a value that is predictable and compatible with the time constraints of the concerned signals.
Use Case:	A legitimate authenticated frame is verified and passed to the receiving ECU within the expected time-frame without experiencing signal monitoring errors.
Corresponding SecOC Requirement	SRS_SecOC_00025
Status	Accomplished

B. Specification

CINNAMON is, as SecOC, part of the Communication Services of the AUTOSAR Classic Platform, as depicted in Fig. 3. It encapsulates the SecOC module and inherits its API

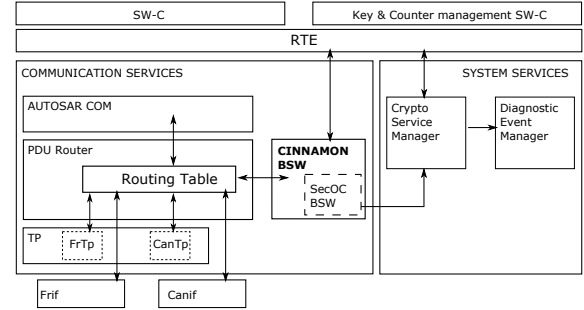


Fig. 3: Integrating CINNAMON BSW module in AUTOSAR

to interact with the PDU Router component (in this version to only manage CAN frames) and with the cryptographic services provided by the *Crypto Service Manager*. Also, our module interacts with the Run-Time Environment to manage counters and keys.

CINNAMON acts as a middle-layer between the low-layer communication module, i.e., TP, and the upper layer software module, i.e., AUTOSAR COM. In addition, our module internally manages the communication with the lower level to build and send the secured data using a single CAN frame. Differently, the last version of SecOC specification [5] suggests to use two PDUs, one dedicated to store information used to authenticate the sender of the frame, and another one containing the secured frame.

1) *Authentication and Integrity:* CINNAMON inherits SecOC authentication and integrity mechanisms, reviewed in Fig. 4.

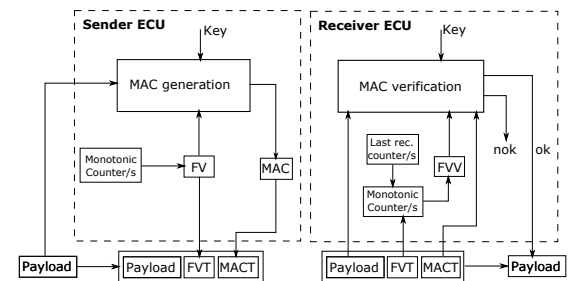


Fig. 4: SecOc MAC Generation and Verification [5]

AUTOSAR assumes that all ECUs have the cryptographic keys to handle Message Authentication Codes (MACs) (see [4]). Moreover, an external Freshness Manager provides counters to both sender and receiver to support the freshness of exchanged frames.

CINNAMON inherits the same prerequisites, briefly recalled here. Let us consider a sender ECU and a receiver ECU. Before sending a payload, the sender generates the

MAC starting from the payload and possibly the *Freshness Value* calculated according to the Monotonic Counter (Fig. 4) provided by the Freshness Manager (an ECU may decide to ignore the Freshness Value). So, the secured CAN frame is composed by the payload, the truncated MAC (MACT in Fig. 4) and, optionally, the truncated freshness value (FVT).

The receiver has to validate the CAN frame before accepting it and does this by verifying the MAC. In fact, the receiver generates a freshness value for verification (FVV) starting from the Monotonic Counter (Fig. 4) received by the Freshness Manager and the previously received freshness value (the latest received counter in Fig. 4). Then, it calculates the MAC by using the received payload and the FVV. If the outcome equals the received MACT, then the payload is accepted, otherwise it is discarded.

The CINNAMON module turns an AUTOSAR secured CAN frame into a CINNAMON secured CAN frame; its data field is presented in Fig. 5. A CINNAMON secured CAN frame is formed by reducing the dimension of the payload. Then, a freshness value is used to guarantee that the frame content is fresh. To complete the data field, an additional block is used for the Message Authentication Code (MAC), which ensures authentication and integrity. Finally, the entire 64 bits of the payload are encrypted to ensure confidentiality.

2) *Confidentiality*: CINNAMON aims at this property by taking the *MAC-then-Encrypt* approach. Let k represent the encryption key, τ the tag and ν the payload. What happens in operational terms is that the tag τ is appended to the payload ν . Then, both the payload and the MAC are encrypted getting $C = ENC(k, \nu || \tau)$. The opposite approach is *Encrypt-then-MAC*, where $C = ENC(k, \nu) || \tau$, namely the MAC is calculated on the encrypted payload. Depending on the chosen algorithm and on the length of the frames, the *MAC-then-Encrypt* approach may turn out less secure than the *Encrypt-then-MAC* approach due to message padding, which may allow an attacker to break the security of the message rebuilding [31]. However, this risk is zeroed in our case because there is no padding effect due to the fixed length of the considered messages.

There is a second reason in support of our choice. The *MAC-then-Encrypt* approach encrypts 64-bit long frames (using encryption algorithms with 64-bit block size and no need for padding). By contrast, using the *Encrypt-then-MAC* approach according to the AUTOSAR specification, the payload (or payload plus FVT) is shorter than 64 bits hence padding would be needed. Most importantly, in frames where the 64 bits are already taken, adding a MAC would necessarily require the transmission of an additional frame to contain it [16].

A potential advantage of *Encrypt-then-MAC* could occur upon verification through the possibility to test the validity of the MAC as soon as the frame is received. However, this would not apply to CINNAMON because receiver needs to have the plain payload to validate the MAC.

C. Security Profiles

As in the Secure On Board Communication module, also in the CINNAMON module it is possible to define and manage various security profiles. *Security profiles* provide a consistent set of values for a subset of parameters that are relevant for the configuration of CINNAMON [5]. A CINNAMON security profile is defined as the configuration of the following mandatory parameters.

- `algorithmFamily:String [0..1]` is the first parameter that characterises the used authentication algorithm. This parameter identifies the family of authentication algorithms.
- `algorithmMode:String [0..1]` is the second parameter that characterises the used authentication algorithm. This parameter identifies which MAC algorithm of the family is used.
- `algorithmSecondaryFamily:String [0..1]` is the third parameter that characterises the used authentication algorithm. This parameter identifies a secondary family of authentication algorithms, if any.
- `authInfoTxLength:PositiveInteger` denotes the length of the truncated MAC.
- `freshnessValueLength:PositiveInteger` denotes the length of the generated freshness value.
- `freshnessValueTruncLength:PositiveInteger` denotes the length of the truncated freshness value inserted in a frame.
- `algorithmFreshnessValue:String [0..1]` denotes the algorithm used to generate the freshness value.
- `algorithmEncryption:String [0..1]` denotes the encryption algorithm.

Note that the first six parameters are inherited from SecOC, while the last two are typical of CINNAMON.

This paper defines one example security profile, given in Table VII. It can be seen that it requires 24 bits for the truncated MAC, and this is coherent with the choice of SecOC. It relies on Chaskey MAC, which is robust under tag truncation [25] and on SPECK64/128, a lightweight block cipher publicly released by the NSA [7].

It is clear that the very definition of this security profile was influenced by feedback from our experiments, as we shall see (§VI).

TABLE VII: Example CINNAMON Security Profile

Parameter	Configuration Value
<code>algorithmFamily</code>	Chaskey
<code>algorithmMode</code>	Chaskey_MAC
<code>algorithmSecondaryFamily</code>	not set
<code>SecOCFreshnessValueLength</code>	not set
<code>SecOCFreshnessValueTruncLength</code>	not set
<code>SecOCAuthInfoTruncLength</code>	24 bit
<code>algorithmFreshnessValue</code>	not set
<code>algorithmEncryption</code>	SPECK64/128

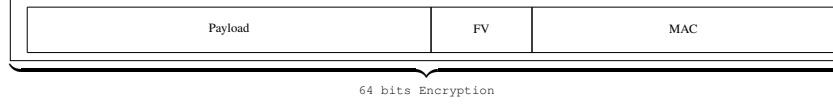


Fig. 5: The CINNAMON Secured CAN Data field

V. SECURITY ASSESSMENT

This section presents an informal security assessment of CINNAMON in comparison to SecOc. We assume a scenario in which an attacker does not have total control of ECUs, hence she does not have privileged access to the boards and cannot see the cryptographic keys each board stores, for example protected under an HSM. The assessment can be compactly represented as in Table VIII, which relates the security properties, and in Table IX, which displays mitigation of threats.

TABLE VIII: Security Properties

Security Property	SecOC	CINNAMON
Confidentiality	○	●
Authentication	●	●
Integrity	●	●
Freshness	●	●

TABLE IX: Mitigated Threats

Threats	SecOC	CINNAMON
Replay	●	●
Tampering	●	●
Forging	●	●
Fuzzing	●	●
Masquerading	●	●
Information Gathering	○	●

It is visible that CINNAMON counters information gathering by aiming at the confidentiality property. However, this must be further spelled out. It means that a module implementation that is SecOC compliant still brings an appreciable inherent risk that an attacker sniffs CAN frames, attempts to interpret them and continues with fuzzing to observe the reactions of target ECUs. The attacker may ultimately learn the semantics of each observed frame and, eventually, re-create the whole DBC of the vehicle. Remarkably, this could be possible even without any access to the MAC keys because frames are sent in the clear. CINNAMON minimises such risk.

On the other hand, we concede that, should the attacker manage to fully compromise an ECU gaining access to all its stored keys, both modules would become ineffective. However, this scenario is thwarted at another level, that of hardware-based security, an area of ferment at least in the last two decades. As a start, the already mentioned HSMs, such as ARM TrustZone [2], protect the memory areas that stores keys. We could even conjecture several levels of increasing hardware protection (and costs) depending on the specific protection requirements of the given application scenario. For example, the encryption key could be stored in a TPM 2.0 and the MAC

key in an HSM, an architecture that would cause multiple violation efforts to the attacker.

VI. OUTLINE OF PROTOTYPE IMPLEMENTATION

A prototype implementation of the CINNAMON security profile seen above is available. Its main features and performances are outlined here, while the full details are published elsewhere [8], [9].

Coherently with the definition of the profile, no parameters related to freshness are used, so the secured frame consists of 40 bits for the payload and 24 bits for the MAC. Encryption is the outermost operation, as it was required.

A. Testbed

Our prototype is deployed on two STM32F407 Discovery boards, each with an ARM Cortex M4 processor. The boards provide physical input buttons, plus light emitting diodes for visual outputs. Both are connected to a workstation via a USB-to-CAN interface.

B. Implementation complexities

Our initial choice to use Chaskey as a MAC function upon the basis of its specifications was a lucky one. The function was reasonably easy to implement and appreciably fast since the initial experiments. Tags were truncated to 24 bits.

However, the encryption algorithm had to be chosen with care. Our obvious, initial candidate was AES but it produced a data field of at least 128 bits, while we aimed at a data field of 64 bits only, coherently with Fig. 5, so that it could be accommodated in just one frame. On the other hand, a 64 bit version of AES would be weaker and is not standardised. We also experimented with DES, 3DES and Blowfish, but their main drawback for our application was the computational overhead. By contrast, SPECK64/128 uses a 128 bit key, produces a 64 bit output and is lightweight, so it turns out the optimal candidate here.

C. Demonstration

The sender board is in charge of sending secured frames. The board uses a 128 bit key to calculate the MAC on the given 40 bit payload and then truncates the resulting tag to 24 bits to complete the allowed 64-bit data field. After that, the payload is encrypted with SPECK 64/128 and finally sent to the other board over the bus.

When the other board receives the secured frame, it first decrypts the entire payload of 64 bits, then it calculates the MAC on the 40 bit payload. It truncates the live MAC to 24 bits and compares it with the 24 bits of the MAC received from the sending board. If all checks succeed, then the board turns on the blue led, otherwise it turns on the red led.

D. Performances

The additional computational overhead due to the management of MACs and of encryption could be a deal breaker. As said above, it was inevitable to proceed by trial and error, with some candidate encryption schemes that had to be abandoned. However, we were pleased to observe that handling the Chaskey/SPECK pair only negligibly reflects on the overall performance. Despite the use of inexpensive hardware with clock at 168 MHz, we face an average of under $6\mu s$ to generate or interpret a secured frame.

VII. RELATED WORK

The current literature has several contributions around the lack of security of the CAN bus. Some solutions refer to the software level, others to the protocol level.

Among the software solutions is TACAN [33], a covert-channel based solution. It shares a master key between an ECU and the Monitor Node to generate shared session keys. These are assumed to be stored in a tamper-resistant memory of a security module, such as the Trusted Platform Module (TPM) [20]. Each ECU embeds unique authentication frames into CAN frames and continuously transmits them through covert channels, which can be received and verified by the Monitor Node. TACAN aims at mitigating suspension, injection and masquerade attack. With respect to TACAN, CINNAMON also mitigates other attacks, such as information gathering and fuzzing attack.

Authentication has been most considered. It is the aim of CANAuth [30], based on CAN+ [35], which is an extension of the basic CAN protocol, and of MaCAN [26], a centralized authentication protocol based on broadcast-based authentication. LCAP [19] is a protocol for frame authentication, resistance to replay attacks, and backward compatibility at the same time. Libra-CAN [18] is a protocol based on a MAC calculated using MD5. CaCAN [23] also introduces a key distribution phase inherited from existing protocols. The protocol needs a new component to be inserted in the vehicular network in order to act as a monitoring node. Frames are not sent in broadcast but on a peer-to-peer base. In LeiA [27], for each frame, the protocol sends a frame in plain-text and another one with the MAC of the frame.

CANcrypt [1] is closely related to our work but is not AUTOSAR compliant. Also TLS-based approaches are valid but demand extra-vehicular Internet connectivity and are limited to time-critical applications due to performance overhead [34].

The general limitation of all these approaches is the lack of integration with the AUTOSAR platform and, in particular, with the current SecOC module. By contrast, we have seen that the CINNAMON module integrates with AUTOSAR and enables protocols to be implemented in compliance with its security profiles.

A framework for the specification and automatic generation of security features for communications among AUTOSAR-compliant components must be mentioned [10]. It allows AUTOSAR designers to add security specifications to the communication model through a dedicated software tool.

However, it has not yet been practically used to advance new components or protocols that would combine confidentiality with authentication and integrity.

VIII. CONCLUSIONS AND FUTURE WORK

CINNAMON is an AUTOSAR compliant basic software module for confidentiality, integrity and authenticity on CAN bus. It is designed as an enhancement of the Secure On-board Communication (SecOC) module [5] and inherits its freshness mechanisms. The main distinctive feature is that CINNAMON manages confidential CAN communication by encrypting CAN frames, hence it effectively thwarts information gathering attacks.

CINNAMON is scalable in the sense that it can host additional security profiles that become necessary depending on the application domain. It is reassuring that the current profile has reached the level of a prototype implementation whose performances are promising on inexpensive hardware. As ongoing work, we are defining new security profiles and are working on a possible implementation for each. As future work, we plan to extend CINNAMON to secure not only the CAN bus but also other buses, such as CAN-FD and Ethernet. This picture supports the claim that CINNAMON is feasible.

ACKNOWLEDGEMENT

This work has been partially supported by the COSCA research project (NGI_TRUST 2nd Open Call (ref: NGI_TRUST 2019002)).

REFERENCES

- [1] Embedded Systems Academy. CANcrypt. <https://www.cancrypt.eu/>, 2018.
- [2] ARM. Arm TrustZone Technology, 2020.
- [3] AUTOSAR. Requirements on Secure Onboard Communication, 2019.
- [4] AUTOSAR. Specification of Key Manager, 2019.
- [5] AUTOSAR. Specification of Secure Onboard Communication AUTOSAR CP R19-11, 2019.
- [6] BBC. Hack attacks mounted on car control systems. <https://www.bbc.com/news/10119492>, 2010.
- [7] Ray Beaulieu, Douglas Shors, Jason Smith, Stefan Treatman-Clark, Bryan Weeks, and Louis Wingers. The simon and speck families of lightweight block ciphers. Cryptology ePrint Archive, Report 2013/404, 2013. <https://eprint.iacr.org/2013/404>.
- [8] Giampaolo Bella, Pietro Biondi, Gianpiero Costantino, and Ilaria Matteucci. Are you secure in your car?: poster. In *Proceedings of the 12th Conference on Security and Privacy in Wireless and Mobile Networks, WiSec 2019, Miami, Florida, USA, May 15-17, 2019*, pages 308–309. ACM, 2019.
- [9] Giampaolo Bella, Pietro Biondi, Gianpiero Costantino, and Ilaria Matteucci. TOUCAN: A protocol to secure controller area network. In *Proceedings of the ACM Workshop on Automotive Cybersecurity, AutoSec@CODASPY 2019, Richardson, TX, USA, March 27, 2019*, pages 3–8, 2019.
- [10] Cinzia Bernardeschi, Marco Di Natale, Gianluca Dini, and Dario Varano. Modeling and generation of secure component communications in AUTOSAR. In *Proceedings of the Symposium on Applied Computing, SAC '17*, page 1473–1480, New York, NY, USA, 2017. Association for Computing Machinery.
- [11] Mario Luca Bernardi, Marta Cimitile, Fabio Martinelli, and Francesco Mercaldo. Driver and Path Detection through Time-Series Classification. *Journal of Advanced Transportation*, 2018:1–20, 2018.
- [12] Charlie Miller Chris Valasek. Adventures in Automotive Networks and Control Units, 2020.

- [13] Lucian Constantin. Researchers hack Tesla Model S with remote attack. <https://www.pcworld.com/article/3121999/researchers-demonstrate-remote-attack-against-tesla-model-s.html>, 2016.
- [14] National Instruments Corporation. FlexRay Automotive Communication Bus Overview, 2020.
- [15] Gianpiero Costantino and Ilaria Matteucci. CANDY CREAM - hacking infotainment android systems to command instrument cluster via can data frame. In Meikang Qiu, editor, *2019 IEEE International Conference on Computational Science and Engineering, CSE 2019, and IEEE International Conference on Embedded and Ubiquitous Computing, EUC 2019, New York, NY, USA, August 1-3, 2019*, pages 476–481. IEEE, 2019.
- [16] Luca Dariz, Michele Selvatici, Massimiliano Ruggeri, Gianpiero Costantino, and Fabio Martinelli. Trade-off analysis of safety and security in CAN bus communication. In *5th IEEE International Conference on Models and Technologies for Intelligent Transportation Systems, MT-ITS 2017, Naples, Italy, June 26-28, 2017*, pages 226–231. IEEE, 2017.
- [17] European Data Protection Board. Guidelines 1/2020 on processing personal data in the context of connected vehicles and mobility related applications. https://edpb.europa.eu/sites/edpb/files/consultation/edpb_guidelines_202001_connectedvehicles.pdf, 2020.
- [18] Bogdan Groza, Stefan Murvay, Anthony Van Herrewege, and Ingrid Verbauwhede. Libra-can: a lightweight broadcast authentication protocol for controller area networks. In *International Conference on Cryptology and Network Security*, pages 185–200, Cham, 2012. Springer.
- [19] Ahmed Hazem and HA Fahmy. Lcap-a lightweight can authentication protocol for securing in-vehicle networks. In *10th escar Embedded Security in Cars Conference, Berlin, Germany*, volume 6, 2012.
- [20] International Organization for Standardization. ISO/IEC 11889-1:2015 - Trusted Platform Module library. <https://www.iso.org/standard/66510.html>, 2015.
- [21] International Organization for Standardization. Road vehicles — Controller area network (CAN) — Part 1: Data link layer and physical signalling. <https://www.iso.org/standard/63648.html>, 2015.
- [22] Jeff Crume. OwnStar: Yet another car hack. <https://insideinternetsecurity.wordpress.com/2015/08/05/ownstar-yet-another-car-hack/>, 2015.
- [23] Ryo Kurachi, Yutaka Matsubara, Hiroaki Takada, Naoki Adachi, Yukihiro Miyashita, and Satoshi Horihata. Cacan-centralized authentication system in can (controller area network). In *14th Int. Conf. on Embedded Security in Cars (ESCAR 2014)*, 2014.
- [24] Miro Enev, Alex Takakuwa, Karl Koscher, and Tadayoshi Kohno. Automobile Driver Fingerprinting. https://petsymposium.org/2016/files/papers/Automobile_Driver_Fingerprinting.pdf, 2016.
- [25] Nicky Mouha, Bart Mennink, Anthony Van Herrewege, Dai Watanabe, Bart Preneel, and Ingrid Verbauwhede. Chaskey: An efficient mac algorithm for 32-bit microcontrollers. In Antoine Joux and Amr Youssef, editors, *Selected Areas in Cryptography – SAC 2014*, pages 306–323, Cham, 2014. Springer International Publishing.
- [26] O.Hartkopp, C. Reuber, and R.Schilling. Macan message authenticated can. 2012.
- [27] Andreea-Ina Radu and Flavio D. Garcia. Leia: A lightweight authentication protocol for can. In Ioannis Askoxylakis, Sotiris Ioannidis, Sokratis Katsikas, and Catherine Meadows, editors, *Computer Security – ESORICS 2016*, pages 283–300, Cham, 2016. Springer International Publishing.
- [28] European Union. General Data Protection Regulation(EU Regulation 2016/679). <https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L:2016:119:FULL>, 2016.
- [29] Chris Valasek and Charlie Miller. Remote Exploitation of an Unaltered Passenger Vehicle. <http://illmatics.com/Remote%20Car%20Hacking.pdf>, 2015.
- [30] Anthony Van Herrewege, Dave Singelee, and Ingrid Verbauwhede. Canauth-a simple, backward compatible broadcast authentication protocol for can bus. In *ECRYPT Workshop on Lightweight Cryptography. Vol. 2011.*, 2011.
- [31] Serge Vaudenay. Security flaws induced by cbc padding — applications to ssl, ipsec, wtls... In Lars R. Knudsen, editor, *Advances in Cryptology — EUROCRYPT 2002*, pages 534–545, Berlin, Heidelberg, 2002. Springer Berlin Heidelberg.
- [32] Vector. Solutions for Automotive Ethernet. <https://www.vector.com/int/en/know-how/technologies/networks/automotive-ethernet/>, 2020.
- [33] Xuhang Ying, Giuseppe Bernieri, Mauro Conti, and Radha Poovendran. TACAN: transmitter authentication through covert channels in controller area networks. *CoRR*, abs/1903.05231, 2019.
- [34] Artem Yushev, Mohammed Barghash, Minh Phuong Nguyen, Andreas Walz, and Axel Sikora. Tls-over-can: An experimental study of internet-grade end-to-end communication security for can networks. *IFAC-PapersOnLine*, 51(6):96 – 101, 2018. 15th IFAC Conference on Programmable Devices and Embedded Systems PDeS 2018.
- [35] Tobias Ziermann, Stefan Wildermann, and Jürgen Teich. Can+: A new backward-compatible controller area network (can) protocol with up to 16x higher data rates. In *Proceedings of the Conference on Design, Automation and Test in Europe*, pages 1088–1093. European Design and Automation Association, 2009.